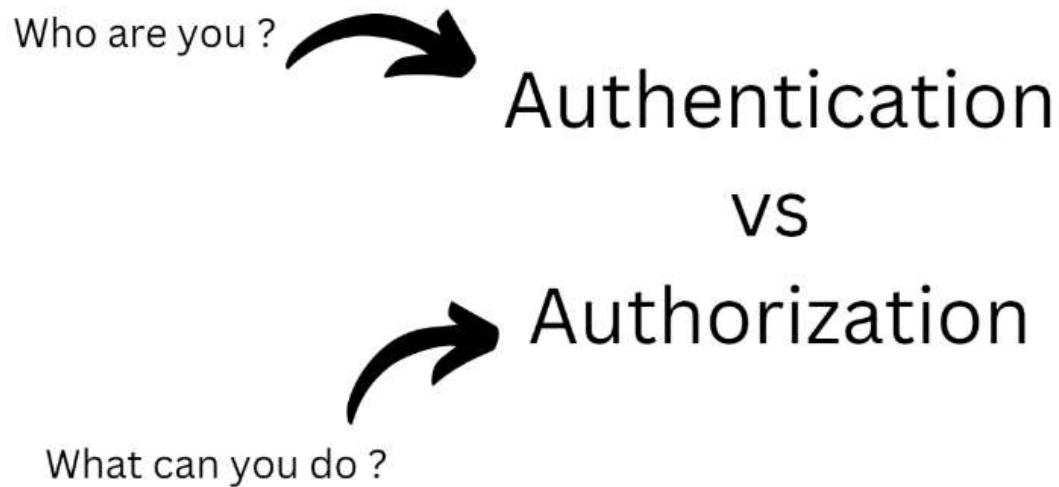


Authentication vs Authorization



Authentication – Authentication is about validating your credentials like Username and password to verify your identity.

Authorization – Authorization is the process to determine whether the authenticated user has access to the particular resources. It checks your rights to grant you access to resources such as information, databases, files, etc.

TYPES OF AUTHENTIFICATIONS

1. Password-Based Authentication

The most common method where users log in using:

- Username / Email
- Password

Ex: Logging into:

- Gmail, LinkedIn, Company portal

2. Multi-Factor Authentication (MFA)

Uses **multiple layers** of verification:

1. Something you know → Password
2. Something you have → OTP / Phone
3. Something you are → Biometrics

Example

- Login → enter password
- Then → enter OTP sent to mobile

3. One-Time Password (OTP) Authentication

Login using a **temporary code** sent via:

- SMS
- Email
- Authenticator app

Example

- Logging into banking apps
- “Login with OTP” option

4. Biometric Authentication

Uses **biological traits**:

- Fingerprint
- Face recognition
- Iris scan

Example

- Unlocking phone with fingerprint
- Face ID on apps

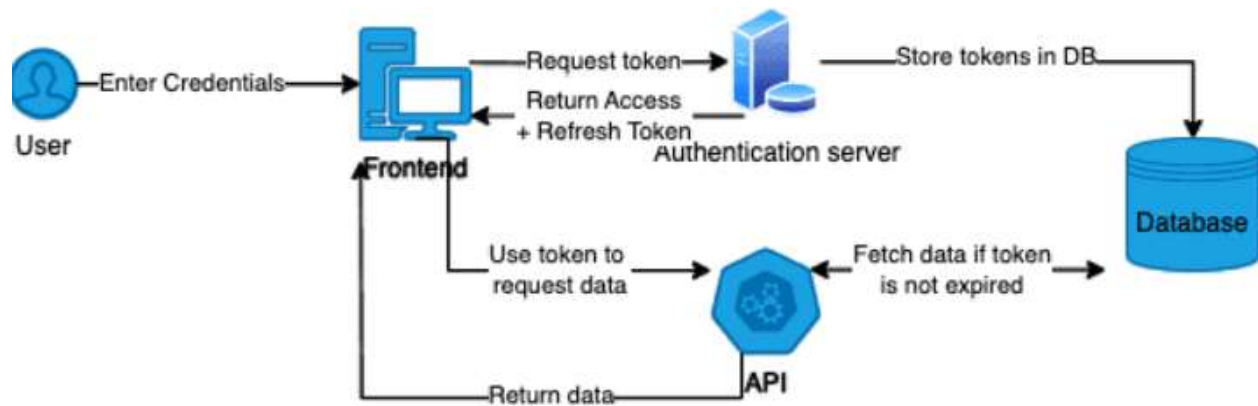
5. Token-Based Authentication

After login, system gives a **token** (like a pass)

User uses that token for future requests

Example

- Login → get token
- Access APIs using token



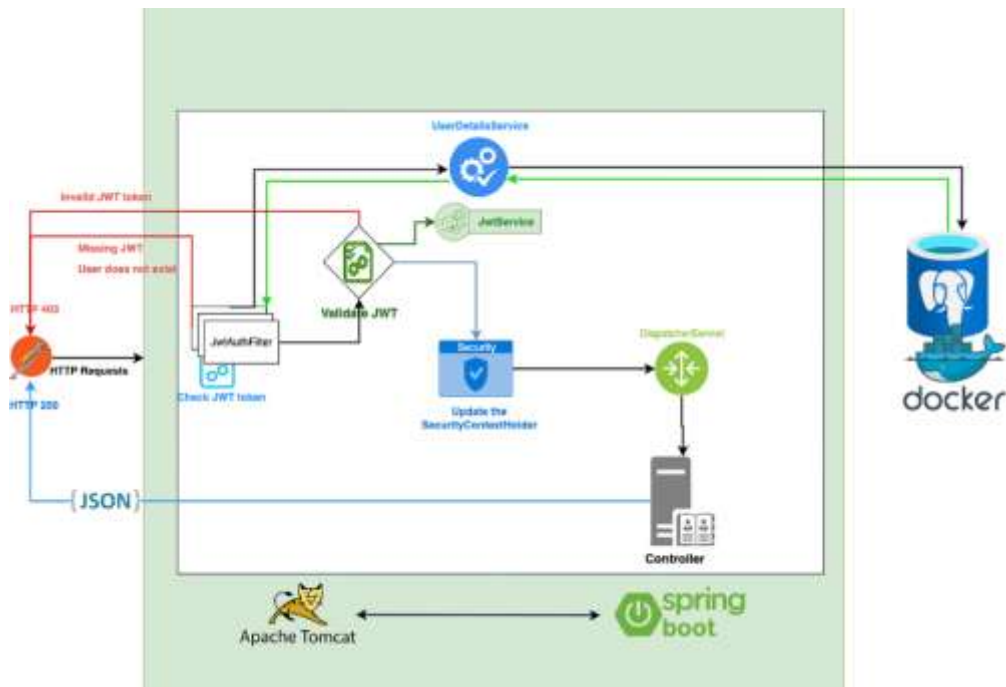
6. JWT (JSON Web Token) Authentication

A special type of token that contains:

- User identity
- Roles
- Expiry

Example

- Most modern APIs (Spring Boot, microservices)



7. OAuth / Social Login

Login using another platform:

- Google
- GitHub
- Facebook

Login with Facebook

Login with Twitter

Login with Google+

OR

Sign in manually

Username or email

Password

☐ Remember me

LOGIN

[Register now](#) | [Forgot password?](#)

8. Session-Based Authentication

Server creates a **session** after login

Client stores a **session ID (cookie)**

Example

- Traditional web apps (banking sites)

Type	Best Use Case
Password	Basic apps
MFA	High security systems
OTP	Quick login
Biometrics	Mobile apps
JWT	APIs / Microservices
OAuth	Social login
Session	Traditional web apps

TYPES OF AUTHORIZATION

1. Role-Based Access Control (RBAC)

Access is based on **roles**

Example

Role	Access
USER	View data
ADMIN	View + Edit + Delete
MANAGER	Approve requests

2. Attribute-Based Access Control (ABAC)

Access based on **attributes** like:

- User role
- Location
- Time
- Department

Example

- Employee can access data:
 - Only during office hours
 - Only from office network

3. User-Based Authorization

Access granted to **specific users**

Example

- Only “Surya” can access a specific report

4. Policy-Based Authorization

Access controlled using **rules/policies**

Example

- “Only managers with 5+ years experience can approve budgets > 1 lakh”

5. Resource-Based Authorization

Access depends on **resource ownership**

Example

- You can edit:

- Your own profile
- Your own documents

6. Scope-Based Authorization (OAuth APIs)

Access defined by **scopes**

Example

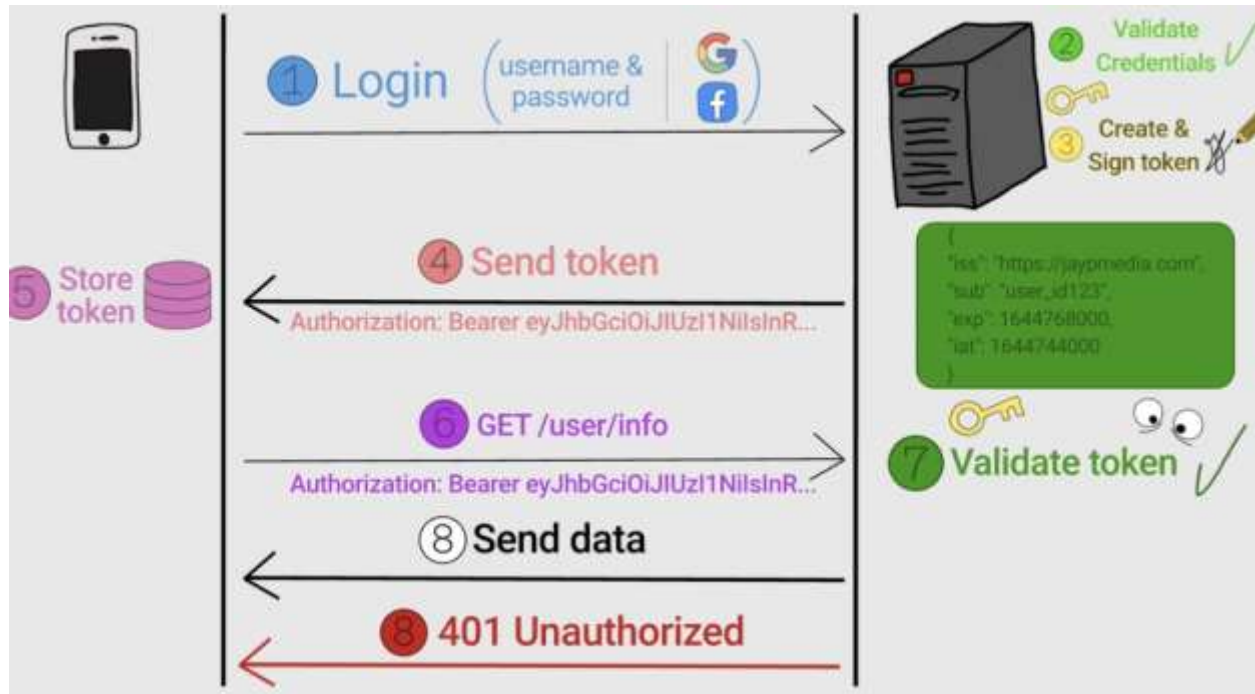
- Google API:
 - read_profile
 - read_email

Type	Best Use Case
RBAC	Most applications
ABAC	Enterprise systems
User-Based	Small systems
Policy-Based	Complex workflows
Resource-Based	APIs (very important)
Scope-Based	OAuth / APIs

End-to-End Flow (Real Application)

1. User enters login credentials
2. Backend validates credentials
3. If valid → generates JWT token
4. Client stores token (localStorage / memory)
5. Client sends token in every API request
6. Backend validates token
7. Backend checks user roles/permissions
8. Allows or denies access

Authentication Flow



Authorization Flow

